

Narrativa Explicativa del Marco FAICP

Por qué medimos lo que medimos, y cómo evitar que los números mientan

"Medir es gobernar. Pero medir mal es gobernar peor que no medir."

— Parafraseando a William Edwards Deming, con la ironía que merece el momento.

Versión: 1.0 — Abril 2026

Audiencia: CISOs, responsables de riesgo, auditores, directivos y cualquiera que deba explicar este marco a alguien que lo mire con escepticismo justificado.

1. El Problema que este Marco Intenta Resolver

Existe una patología bien documentada en la gestión de la ciberseguridad: la proliferación de métricas que miden la actividad en lugar del riesgo, la presencia de controles en lugar de su efectividad, y el cumplimiento normativo en lugar de la resiliencia real. El informe CISO de Gartner 2024 lo denomina "security theater": la ilusión de control medido que proporciona confort a los consejos de administración sin reducir materialmente la exposición al riesgo.

El FAICP y su aplicación mediante GQM + PRAGMATIC nace precisamente para romper ese teatro. La metodología GQM fuerza a que cada métrica nazca de una pregunta concreta, y cada pregunta de un objetivo verificable. PRAGMATIC añade una capa de control de calidad de las propias métricas, asegurando que lo que se mide tiene propiedades deseables: que predice, que es genuino, que genera acción.

Lo que sigue es la explicación de las decisiones metodológicas más importantes tomadas en el diseño del marco IGM-FAICP, con la honestidad de reconocer sus limitaciones y la ambición de sus posibilidades.

2. Por qué GQM y no simplemente "controles del NIST"

La diferencia entre adoptar un catálogo de controles (NIST CSF, ISO 27001, ENS) y aplicar GQM es la diferencia entre tener una biblioteca y saber leer. Los catálogos de controles son herramientas excelentes para saber qué controles existen; GQM es la metodología que responde a si esos controles son los adecuados para los objetivos específicos de esta organización, en este contexto, con este perfil de riesgo.

En el contexto español, los objetivos nacionales no son abstractos: el Plan Nacional de Ciberseguridad 2025 comprometió 1.157 millones de euros con objetivos específicos. La Estrategia Nacional de Inteligencia Artificial enmarca el despliegue de IA en la AAPP y el sector privado. El EU AI Act impone obligaciones concretas a organizaciones concretas. GQM traduce esos objetivos políticos en preguntas operativas, y esas preguntas en datos que se pueden recoger.

La alternativa —ignorar los objetivos y directamente implementar controles— produce lo que en ingeniería de software se denomina "gold plating": implementar controles sofisticados que nadie necesita mientras las brechas elementales permanecen abiertas. El 70% de las organizaciones españolas

no detecta Shadow AI; implementar monitorización de model drift sin resolver primero el AI-BOM es exactamente esa trampa.

3. La Lógica de los Pesos del IGM

Los pesos asignados a las seis funciones del CSF 2.0 en el IGM-FAICP no son arbitrarios, aunque cualquier sistema de pesos tiene un componente inevitablemente subjetivo que debe reconocerse con honestidad.

GOBERNAR (0.20) e IDENTIFICAR (0.20) tienen el mismo peso porque son las funciones habilitadoras. Sin gobernanza, no hay mandato para implementar nada. Sin identificación, no se sabe qué proteger. Son condición necesaria de todas las demás funciones.

PROTEGER (0.25) tiene el mayor peso individual porque concentra la mayor densidad de controles técnicos con impacto directo en la superficie de ataque. Es donde más se puede hacer y más se puede medir con objetividad técnica.

DETECTAR (0.15) tiene un peso menor no porque sea menos importante —es crítica— sino porque en el dominio de la IA adversarial, la detección tiene limitaciones estructurales que los controles preventivos no tienen. Un sistema de IA con prompt injection silenciosa puede funcionar "correctamente" según todas las métricas de rendimiento mientras produce outputs comprometidos. La detección es el control del que menos se puede esperar en el corto plazo.

RESPONDER y RECUPERAR (0.10 cada una) no tienen peso bajo porque sean menos importantes en términos de impacto de negocio —en un incidente real son las funciones más críticas—, sino porque en el modelo de madurez progresivo, su efectividad depende fuertemente de las funciones anteriores. Responder bien sin haber identificado bien es imposible.

La honestidad metodológica obliga a señalar que estos pesos deberían **revisarse por sector**: para un banco supervisado por DORA, el peso de RECUPERAR debería ser mayor. Para una AAPP con sistemas de IA en servicios críticos, GOBERNAR debería tener mayor peso. El IGM-FAICP base es un punto de partida, no un dogma.

4. La Trampa del Criterio G (Genuino)

De los nueve criterios PRAGMATIC, el más problemático en la práctica es G (Genuino): la capacidad de una métrica de medir lo que dice medir sin ser distorsionada por incentivos de quien la produce.

En la ciberseguridad corporativa, los incentivos son adversos a la genuinidad: el CISO cuya valoración depende de las métricas que reporta tiene un incentivo estructural para reportar métricas favorables. Esto no es cinismo; es diseño organizativo deficiente.

En el contexto del FAICP, los riesgos de gaming más específicos son:

En IGM-GV-01 (Política de ciberseguridad IA): Presentar una política genérica de ciberseguridad con el título actualizado ("...para sistemas de IA") sin añadir ningún contenido específico. Mitigación: el

checklist de elementos obligatorios debe verificarse elemento por elemento, con evidencia de implementación para cada uno.

En IGM-ID-01 (AI-BOM): Elaborar un inventario de los sistemas de IA "conocidos" omitiendo el Shadow AI que satura el 70% de las organizaciones españolas. Mitigación: herramientas de descubrimiento automático (análisis de tráfico de red, análisis de contratos cloud, revisión de tarjetas de crédito corporativas para suscripciones SaaS de IA).

En IGM-RS-04 (MTTR-AI): Medir el tiempo de cierre del ticket en el sistema de gestión de incidentes en lugar del tiempo real de contención del incidente. Un ticket puede cerrarse con el incidente todavía activo. Mitigación: el MTTR debe medirse contra el momento de contención verificada (evidencia técnica), no contra el cierre administrativo.

En IGM-RC-02 (RTO-AI): Definir el RTO como un objetivo en el BCP sin verificar que es alcanzable en ejercicios reales. Mitigación: el RTO solo cuenta como Puntuación 6 si está "validado en ejercicio de recuperación real", no si simplemente está documentado.

La recomendación práctica más importante sobre genuinidad es esta: **separar quien mide de quien es medido**. Siempre que sea posible, la evaluación IGM-FAICP debería ser realizada por un equipo o entidad diferente a la que implementa los controles.

5. Los Tres Indicadores Condicionales: Por qué son Condicionales y cuándo se Volverán Recomendados

IGM-ID-03 (Consumo de CTI IA adversarial) — Condicional por inmadurez del mercado

El mercado de inteligencia de amenazas específica para IA adversarial existe pero no ha madurado. MITRE ATLAS es el referente más cercano a un feed CTI estructurado para IA, pero su actualización es periódica (no continua) y su cobertura de incidentes reales es aún limitada. Los feeds comerciales de CTI que incluyen técnicas ATLAS son contables con los dedos de una mano en 2026, y la mayoría las incluyen como categoría marginal.

Este indicador se volverá "Recomendado" cuando: (a) los principales proveedores de SIEM/SOAR integren reglas nativas de MITRE ATLAS, (b) ENISA publique un feed específico de amenazas IA para Europa, o (c) INCIBE incorpore categorías de IA adversarial en su catálogo de indicadores de compromiso compartidos.

IGM-DE-04 (Capacidades SOC para amenazas IA) — Condicional por escasez de capacidades

Pedir a un SOC que detecte ataques de envenenamiento de modelos o inyección de prompt indirecta en 2026 es como pedir en 2005 que detectara ataques APT: no es que no sea deseable, es que las herramientas, el entrenamiento y el personal necesarios no existen todavía en el mercado a escala.

Esto no significa que la brecha no deba medirse —de hecho, medirla es el primer paso para cerrarla—, sino que la interpretación de puntuaciones bajas (1-2) en este indicador debe hacerse con la conciencia

de que la mayoría de organizaciones, incluso muy maduras, también puntúan bajo. El benchmarking es el antídoto al perfeccionismo inmovilizador.

IGM-RS-02 (Forense de sistemas IA) — Condicional por escasez de profesionales

El análisis forense digital tiene décadas de desarrollo. El análisis forense específico de sistemas de IA — reconstrucción de secuencias de prompts, análisis de activación de capas de una red neuronal, trazabilidad de decisiones de un agente— es una disciplina naciente. La comunidad de profesionales con estas capacidades es pequeña, los estándares forenses para IA no están definidos, y las herramientas comerciales de forense IA son pre-comerciales.

La recomendación práctica es comenzar a documentar ahora los logs de inferencia con suficiente granularidad para que sean analizables cuando las capacidades forenses IA maduren. El coste de implementar logging adecuado hoy es mínimo comparado con el de no tener datos forenses en un incidente futuro.

6. El Indicador más Subestimado: IGM-RC-03

De todos los indicadores del marco, el más novedoso conceptualmente —y el más subestimado en los marcos de continuidad convencionales— es IGM-RC-03: la capacidad de revisar y potencialmente revocar las decisiones tomadas por el sistema de IA durante el período en que estuvo comprometido.

El patrón convencional de recuperación ante desastres trata los sistemas como cajas negras: si el sistema ha sido restaurado correctamente, la recuperación está completa. Para sistemas de IA con impacto en decisiones que afectan a personas —concesión de créditos, selección de empleados, decisiones médicas de apoyo, evaluación de solicitudes administrativas—, esto es insuficiente.

Un sistema de IA comprometido durante tres semanas puede haber tomado miles de decisiones sesgadas, incorrectas o malintencionadas. Recuperar el sistema sin revisar esas decisiones no es recuperación: es encubrimiento inadvertido.

El EU AI Act Art. 72.1 aborda este problema al requerir supervisión humana continua y capacidad de intervención. Pero las implicaciones prácticas de IGM-RC-03 van más allá: implican que toda organización con sistemas de IA en decisiones de alto impacto debe tener un procedimiento para:

1. Identificar el período exacto de compromiso
2. Catalogar todas las decisiones tomadas durante ese período
3. Evaluar el impacto potencial de cada categoría de decisión
4. Definir criterios de revisión y umbrales de actuación
5. Notificar a los afectados cuando proceda (RGPD Art. 22, EU AI Act)

Este proceso puede ser costoso, pero su ausencia puede ser más costosa aún: tanto en términos legales (responsabilidad por daños causados por IA comprometida) como reputacionales.

7. Cómo Usar este Marco sin Caer en la Parálisis por Análisis

El marco GQM + PRAGMATIC + IGM-FAICP con 29 indicadores, 6 funciones y múltiples escalas puede producir la respuesta equivocada en muchas organizaciones: intentar implementarlo todo de una vez, paralizarse ante la magnitud del reto, y terminar no haciendo nada.

La recomendación operativa es la **secuenciación por prioridad Tier**:

Mes 1-3 (Tier 1 — Urgente): IGM-GV-01, IGM-GV-05, IGM-ID-01, IGM-PR-01, IGM-DE-02, IGM-RS-01, IGM-RS-03, IGM-RC-01. Estos son los indicadores Tier 1 del NIST IR 8596 y los más críticos del EU AI Act. Sin ellos, el riesgo regulatorio y operativo es máximo.

Mes 4-9 (Tier 2 — Importante): El resto de indicadores de las funciones GOBERNAR, IDENTIFICAR y PROTEGER. Estos consolidan la postura preventiva.

Mes 10-18 (Tier 3 — Avanzado): Los indicadores de DETECTAR y RESPONDER que requieren capacidades SOC avanzadas. Estos son los más difíciles de implementar y los que más dependen de la madurez previa.

La gestión progresiva no es resignación; es estrategia. Un IGM-FAICP de 2.5 construido sobre bases sólidas en 18 meses es más valioso que un IGM-FAICP de 4.0 documentado en papel pero sin implementación real. El criterio G (Genuino) del PRAGMATIC no es solo metodológico: es la brújula moral del marco.

8. El Marco como Conversación, no como Auditoría

El uso más productivo del GQM + PRAGMATIC + IGM-FAICP no es la auditoría anual que produce un número. Es la **conversación continua** que el número hace posible entre:

- El CISO y el Consejo de Administración: "Estamos en 2.8 IGM-FAICP, los indicadores que más nos alejan de 3.5 son IGM-ID-01 (AI-BOM) e IGM-DE-04 (capacidades SOC). Necesitamos inversión específica en estas áreas."
- La AAPP autonómica y AESIA: "El benchmark agregado de las organizaciones de la CCAA muestra que IGM-GV-06 (registro EU AI Act) tiene la puntuación más baja de la región. Necesitamos un programa de apoyo sectorial."
- El INCIBE y el tejido empresarial: "Los incidentes del año pasado (+26% interanual) están concentrados en organizaciones con IGM-RS-01 < 2 (sin playbooks IA). La correlación es estadísticamente significativa."

El CISO y el Consejo de Administración: "Estamos en 2.8 IGM-FAICP, los indicadores que más nos alejan de 3.5 son IGM-ID-01 (AI-BOM) e IGM-DE-04 (capacidades SOC). Necesitamos inversión específica en estas áreas."

La AAPP autonómica y AESIA: "El benchmark agregado de las organizaciones de la CCAA muestra que IGM-GV-06 (registro EU AI Act) tiene la puntuación más baja de la región. Necesitamos un programa de apoyo sectorial."

El INCIBE y el tejido empresarial: "Los incidentes del año pasado (+26% interanual) están concentrados en organizaciones con IGM-RS-01 < 2 (sin playbooks IA). La correlación es estadísticamente significativa."

Estas conversaciones son las que producen mejora. El IGM-FAICP es el idioma que las hace posibles.

Documento parte del Kit FAICP 2025-2026 — Versión 1.0 — Abril 2026

Ver también: (a) Marco GQM + PRAGMATIC, (b) Matriz de Evaluación PRAGMATIC, (d) Mapeo Normativo, (e) Plantilla IGM + ROI